

TRAINING @ FORREST ONE

Session 4 of 12

Network Fundamentals + CompTIA Security+ SY0-701

Fundamental Security Concepts

Confidentiality, integrity, availability, and the controls and roles that protect them.

LESSON 1

DOMAIN 1

CIA TRIAD



WELCOME · THE JOURNEY

Twelve sessions, two strands, one certification

Strand	Sessions	Focus
Network foundation	1–3	Models, addressing, switching, services
Security+ core	4–7	Concepts, threats, crypto, IAM
Security architecture	8–9	Network, endpoint, application, cloud
Operations & governance	10–12	Vuln mgmt, IR, GRC

The exam

90 questions · 90 minutes · performance-based + multiple choice · pass mark 750/900.



SESSION OBJECTIVES

By the end of this session you will be able to

- **Define the CIA triad** confidentiality, integrity, availability
- **Explain non-repudiation** and the three authentication factors
- **Describe AAA** identification, authentication, authorisation, accounting
- **Classify any control** by category and by functional type
- **Apply the NIST CSF** identify, protect, detect, respond, recover, and gap analysis
- **Describe zero trust** never trust, always verify; microsegmentation
- **Explain deception and change control** honeypots and controlled change management
- **Name the key roles** and their responsibilities



CHAPTER 1 · WHY CONTROLS EXIST

Why security controls exist

- **Safeguards and countermeasures** controls manage the risk that threats present to assets
- **They prevent, detect and respond** stop access, find activity, or recover afterwards
- **External threats** a ransomware crew outside the organisation
- **Internal threats** a trusted employee copying files
- **More than technology** policy, procedure and physical barriers all count
- **Risk is treated, not removed** controls lower the likelihood and the impact



CHAPTER 1 · WHY CONTROLS EXIST

The layered view: defence in depth

Idea	What it means	Example
Layered defence	One control failing is not a breach	Firewall, then detection, then logs
Controls in concert	Each covers another control's weakness	Encryption plus access control
Defence in depth	Layers fail independently	Backups survive ransomware
Risk reduction	Lower likelihood, lower impact	Segmentation limits movement

The point of layers

One control is never enough: an attacker past the firewall still meets detection, then the logs.



CHAPTER 2 · CLASSIFYING CONTROLS BY CATEGORY

Technical controls

- **Built into systems** implemented in hardware, software, or both together
- **A firewall** filters traffic between trusted and untrusted networks
- **Encryption** makes intercepted data unreadable without the key
- **Access control lists** state exactly who may reach a resource
- **An intrusion detection system** watches traffic for signs of attack activity
- **No person in the loop** the system enforces policy mechanically



CHAPTER 2 · CLASSIFYING CONTROLS BY CATEGORY

Physical controls

- **They protect** premises, hardware and people
- **Locks** from a simple key to an electronic card reader
- **Fences** mark the perimeter and delay an intruder
- **Cameras** deter an intruder as well as record them
- **A mantrap** a small room where only one door opens at a time
- **Biometric door access** reads a fingerprint or an iris before it releases the lock



CHAPTER 2 · CLASSIFYING CONTROLS BY CATEGORY

Managerial controls

- **Also called administrative** the policies and procedures that govern security
- **Risk assessment** identifies, evaluates and prioritises the risks to an asset
- **Security policy** a formal document stating how information must be protected
- **Training** teaches staff to spot a phishing email and report an incident
- **They set direction** technical controls then enforce that direction
- **Example** a policy mandating strong passwords



CHAPTER 2 · CLASSIFYING CONTROLS BY CATEGORY

Operational controls

- **Day-to-day work** procedures carried out by people, not by systems
- **Guard patrols** check that doors are locked and cameras are working
- **Incident response** identify, contain, eradicate, recover, then review
- **Backup routines** keep data recoverable when hardware fails or ransomware strikes
- **On site and off site** copies are held in both locations
- **The split** managerial controls write the policy, operational controls carry it out



CHAPTER 3 · WHAT EACH CONTROL TYPE DOES

Preventive controls

- **Proactive by definition** they act before an incident happens
- **A firewall** blocks traffic that the rules do not allow
- **Encryption** makes a stolen copy unreadable without the key
- **Security training** a workforce that recognises phishing closes the easiest door
- **Segmentation** stops an infected machine wandering the whole estate
- **The honest part** prevention is never perfect, so pair it with detection



CHAPTER 3 · WHAT EACH CONTROL TYPE DOES

Detective controls

- **They find what prevention missed** detection acts during or after an incident
- **Log monitoring** reviewing system and network logs for unusual activity
- **An intrusion detection system** compares traffic against signatures, or spots anomalies
- **A security audit** evaluates whether the controls you believe in actually work
- **They give visibility** you cannot respond to what you never saw
- **Two different answers** a firewall blocks, and the detector reveals what got through



CHAPTER 3 · WHAT EACH CONTROL TYPE DOES

Corrective controls

- **Damage control** applied after an incident to limit the harm
- **Patch** fix the vulnerability the attacker used, so the door stays shut
- **Restore** recover lost data from backup, to a point before the incident
- **Revise** review the procedures that failed and rewrite the runbook
- **The step organisations skip** revision is the one that stops a repeat
- **Reactive by design** and that is not a fault, it is essential for continuity



CHAPTER 3 · WHAT EACH CONTROL TYPE DOES

Compensating controls

- **An alternative** what you do when the proper control is not feasible
- **Legacy system cannot encrypt?** protect its traffic at the network layer instead
- **No budget for detection?** compensate with enhanced logging and frequent audits
- **An operational need?** add cameras and guarding where production cannot stop
- **Temporary by intent** so it must be documented and reviewed
- **Plan the replacement** swap it out once the proper control becomes possible



CHAPTER 3 · WHAT EACH CONTROL TYPE DOES

Deterrent controls

- **They work on the attacker's mind** not on the traffic
- **A psychological barrier** they do not stop an attack, they discourage it
- **A warning banner** states that unauthorised access is prohibited and may be prosecuted
- **Visible cameras** a recording shifts the odds of being caught
- **Security personnel** raise the perceived risk of an attempt
- **When deterrence fails** an attacker who does not care is not deterred



CHAPTER 3 · WHAT EACH CONTROL TYPE DOES

Directive controls

- **They point inwards** at your own people, not at the attacker
- **Acceptable use policy** states what is allowed on company systems and what is forbidden
- **Procedures** describe the safe way to handle sensitive data
- **They build culture** security is not left to individual judgement
- **Non-compliance** a management issue rather than a technical one
- **Example** the rule that says encrypt before you send anything out



QUIZ

Activity: classify the controls

- A firewall blocking unauthorised ports, category and type?
- A security camera over the server room door, category and type?
- An intrusion detection system watching traffic, type?
- A backup-and-restore plan after ransomware, category and type?
- A legacy system that cannot encrypt, protected by a secure gateway, type?
- Add one control from your workplace to each category.

Category: managerial / operational / technical / physical · Type: preventive / detective / corrective / compensating / deterrent / directive.



CHAPTER 4 · PROVING IDENTITY AND KEEPING RECORDS

The CIA triad

- **Confidentiality** information is disclosed only to those with the right permission
- **Integrity** the data is accurate, complete and unaltered without authorisation
- **Availability** authorised users can reach systems and data when they need them
- **Use it as a question** when you meet a control, ask which pillar it serves
- **The usual answers** encryption and access control, hashing and signatures, redundancy
- **They pull against each other** the three are a balance, not three separate problems



CHAPTER 4 · PROVING IDENTITY AND KEEPING RECORDS

Threats and controls by pillar

Pillar	Typical threat	Control that answers
Confidentiality	Data breach, eavesdropping	Encryption, strong authentication
Integrity	Tampering, man in the middle	Hashes, signatures, version control
Availability	Denial of service, hardware failure	Redundancy, failover, tested backups
All three	Insider misuse	Least privilege, monitoring, audit trails

Version control earns its place

A hash tells you data changed; version control lets you roll back to the last good copy.



CHAPTER 4 · PROVING IDENTITY AND KEEPING RECORDS

Non-repudiation

- **Definition** persons cannot deny creating or modifying data
- **Proof of origin** the sender cannot deny sending the message
- **A digital signature** a hash of the message, encrypted with the sender's private key
- **Why it proves the sender** only that private key could have produced the signature
- **Verification** anyone decrypts the signature with the matching public key
- **Audit logs and timestamps** complete the proof of who acted and exactly when



CHAPTER 4 · PROVING IDENTITY AND KEEPING RECORDS

Analyst's lens: why denial must fail

- **A signed contract** if either party could deny signing, the agreement is worthless
- **A payment authorisation** the bank must prove the account holder authorised the transfer
- **A regulated record** healthcare rules require proof of who accessed and changed a record
- **The control** a signature plus an audit trail provides exactly that proof

The exam line

Non-repudiation is proof, not merely logging. Signatures prove origin; logs prove action.



CHAPTER 4 · PROVING IDENTITY AND KEEPING RECORDS

Authentication: the three factors

- **Something you know** a password, a passphrase or a pin
- **Something you have** a token, a smart card, or an authenticator app
- **Something you are** a biometric such as a fingerprint, a face or an iris
- **Multifactor** two or more different factors, not two of the same kind
- **Two passwords are not MFA** the factor matters more than the technology
- **Why it matters** attackers go for the weakest factor, so add a second



CHAPTER 4 · PROVING IDENTITY AND KEEPING RECORDS

Factors, examples and weaknesses

Factor	Examples	Typical weakness
Know	Password, pin, passphrase	Reuse, phishing, brute force
Have	Token, smart card, app code	Lost or stolen device
Are	Fingerprint, face, iris	Spoofing, privacy concerns
Protocols	Kerberos, LDAP, SAML, SSO	Misconfiguration, weak trust

Know your protocols

Kerberos authenticates, LDAP looks up accounts, SAML passes identity, SSO gives one login.



DISCUSSION

Which pillar of the CIA triad fails first in a typical data breach?

Work through a breach: data is stolen (confidentiality), altered (integrity), or systems go down (availability). Most incidents touch more than one pillar. Name the chain.

Real incidents usually break two or three pillars at once.



BREAK
10 MINUTES

Back soon: accounting and zero trust, then deception and change control.



CHAPTER 5 · ACCOUNTING AND ZERO TRUST

Accounting and audit trails

- **Accounting** recording user activity and resource use, such as logins and config changes
- **The audit trail** a chronological record that traces an action back to a specific user
- **It creates accountability** when actions are recorded, behaviour improves
- **It supports investigation** after a breach, reconstruct events and find the root cause
- **It demonstrates compliance** evidence for the auditor, without any guesswork
- **It reveals policy violations** things no other control would catch



CHAPTER 5 · ACCOUNTING AND ZERO TRUST

Log management

- **Centralise** pull logs from servers, firewalls, endpoints and applications into one place
- **Correlate** see one event across several systems instead of five separate records
- **Set a retention period** keep data long enough for regulation and your own investigations
- **Analyse** where a SIEM earns its place, collecting events and flagging the suspicious
- **Alert automatically** nobody watches a dashboard for eight hours straight
- **The hard truth** a log nobody reads is evidence you will not have



CHAPTER 5 · ACCOUNTING AND ZERO TRUST

Zero trust: never trust, always verify

- **The uncomfortable assumption** threats exist inside the network as well as outside it
- **Why the old model failed** insiders, stolen credentials and cloud services cross the line
- **No implicit trust** no user and no device is trusted by default
- **Every request is checked** authenticated and authorised before it reaches a resource
- **Microsegmentation** isolated zones so an attacker cannot move sideways unchecked
- **The exam line** zero trust is a design principle, not a product you buy



CHAPTER 5 · ACCOUNTING AND ZERO TRUST

Continuous verification and least privilege

- **Not a one-time event** logging in once does not earn lasting trust
- **Continuous assessment** behaviour and context are watched through real-time analytics
- **Adaptive authentication** policy adjusts to risk when behaviour changes
- **An example** a sign-in from an unfamiliar country prompts another check
- **Least privilege** users receive only the access their role requires
- **The trade-off** complex, costly and culturally hard, but less lateral movement



CHAPTER 6 · DECEPTION AND CHANGE CONTROL

Honeypots, honeynets and honeytokens

- **A honeypot** a decoy system that looks like a real server with real services
- **It reveals method** an attacker who engages it shows tooling and intent
- **A honeynet** a whole decoy network built from several systems
- **A honeytoken** a single piece of fake data, such as a bogus account or planted file
- **It raises an alert** the moment somebody touches it
- **Watch for the tell** no legitimate user should ever reach these



CHAPTER 6 · DECEPTION AND CHANGE CONTROL

What deception buys you

- **Early warning** a decoy sits beside production, so any contact is suspicious
- **Threat intelligence** every attacker action on a honeypot is recorded and studied
- **Wasted effort** every moment on a decoy is a moment not spent on real systems

Deception catches what a signature has never seen

A honeypot needs no attack signature, because nobody legitimate should be there at all.



CHAPTER 6 · DECEPTION AND CHANGE CONTROL

A controlled change, step by step

1

Request

what changes, why,
and what benefit

2

**Impact
assessment**

security, functionality,
performance

3

Approval

system owner and
security officer

4

Schedule

a maintenance
window, with a
rollback plan

5

Document

every change,
however minor it looks



CHAPTER 6 · DECEPTION AND CHANGE CONTROL

When change management is skipped

- **An unapproved firewall rule** one small edit can expose an internal service to the internet
- **Unapproved software** brings malware or compatibility problems with it
- **Nobody knows it is there** the change is a back door nobody recorded
- **Configuration drift** systems wander away from the approved baseline
- **The cost** nobody can say what a normal build looks like, so response slows

The rule

An unmanaged change can open a back door, disable a control, or break a dependency.



CHAPTER 6 · DECEPTION AND CHANGE CONTROL

What a change can break

- **Allow list** only pre-approved applications may run, so a new one must be added
- **Firewall rules** a new server needs a rule, and a hasty rule opens a port
- **Security baseline** the minimum standard every build must meet
- **A deprecated protocol** means the baseline itself must change
- **System dependencies** one upgrade can break three systems that rely on it
- **Evaluate all four** before anything is deployed to production



CHAPTER 6 · DECEPTION AND CHANGE CONTROL

Before you approve: evaluate the impact

- **Test first** in a non-production environment, against the controls already in place
- **Ask before, not after** what controls does this change affect?
- **Ask again** what new risk does this change introduce?
- **Write the rollback plan** backup procedures, restoration steps, and a health check

A change without a way back

is a gamble, not a project. Hold the rollback plan before the maintenance window opens.



EXAM ALIGNMENT · DOMAIN 1

The NIST Cybersecurity Framework

1

Identify

know your assets,
systems and risks

2

Protect

implement safeguards
for critical services

3

Detect

find security events
quickly

4

Respond

contain and mitigate
incidents

5

Recover

restore capabilities
and learn

Purpose

A common language and map for the whole security programme. CSF 2.0 adds Govern to the core five.



Gap analysis

- **Definition** comparing the current security posture against a target framework
- **What it finds** missing controls, weak areas and unmeasured functions
- **Output** a scored view, for example 50% maturity in a function
- **The value** prioritised, evidence-based improvement you can measure
- **The distinction** a scan finds technical holes; a gap analysis measures the programme



Core security principles

- **Defence in depth** layered controls, so no single point of failure
- **Least privilege** users get only the access they need, reviewed regularly
- **Separation of duties** no one person controls a critical process alone
- **Zero trust** never trust implicitly; verify every request
- **The thread** each principle limits the blast radius of one failure



EXAM ALIGNMENT · DOMAIN 1

Who does what

Role	Responsibility
CISO / CSO	Executive ownership of security strategy and risk
Information Systems Security Officer (ISSO)	Day-to-day management of security systems and compliance
Data owner	Accountable for a data set's classification and protection
Data custodian	Implements the controls that protect the data
Security analyst	Monitoring, triage and incident response
Auditor	Independent review of controls and compliance



EXAM ALIGNMENT · DOMAIN 1

What this maps to in the exam

Objective	What the exam tests
1.1 Security concepts	CIA triad, non-repudiation, AAA, gap analysis
1.2 Security controls	Categories and functional types
1.3 Security principles	Defence in depth, least privilege, separation of duties, zero trust
1.4 Roles & responsibilities	CISO/CSO, ISSO, data owner, custodian

Two axes, every time

When a question names a control, classify the category first, then the functional type.



QUIZ

Check your understanding

- Open Quiz_Session_04.html in your browser.
- 20 questions, immediate feedback, exam-objective tag on every question.
- Read each explanation: the distractors teach as much as the answer.
- Score 70%+ before moving on.

Every question maps to a CompTIA exam objective, e.g. 1.2 Security Controls.



KEY TAKEAWAYS

- **Controls reduce risk in layers** safeguards, countermeasures, and defence in depth.
- **Category says how** technical, physical, managerial, operational.
- **Type says what** preventive, detective, corrective, compensating, deterrent, directive.
- **CIA anchors every decision** confidentiality, integrity, availability, plus non-repudiation.
- **Identity must be provable** authentication factors, accounting and audit trails.
- **Zero trust verifies every request** never trust, always verify; microsegmentation.
- **Deception and change control** honeypots teach you about attackers; controlled change protects the baseline.



REVISION CHECKLIST

Before next session

- **Retake the quiz** until you score 70%+ without guessing
- **Classify ten controls** five by category and five by functional type
- **Map your workplace** one control for each category and each type
- **Practise the triad** classify five recent incidents by pillar
- **Read ahead** Session 5, threat types, threat actors and attack vectors



NEXT SESSION

Session 5 — Threats, Attack Types & Threat Actors

- Threat actors: nation-state, criminal, insider, hacktivist
- Attack vectors: direct, network, lure-based, supply chain
- The vulnerability-threat-risk relationship

